

Phishing and Countermeasures

Understanding the Increasing Problem
of Electronic Identity Theft

Edited by

Markus Jakobsson

Indiana University
Bloomington, Indiana

Steven Myers

Indiana University
Bloomington, Indiana



WILEY-INTERSCIENCE
A JOHN WILEY & SONS, INC., PUBLICATION

This Page Intentionally Left Blank

In praise of *Phishing and Countermeasures*

In this comprehensive tome, Markus Jakobsson and Steven Myers take us on a rigorous phishing trip through the icy waters of the Internet. Because there is at least one sucker born every minute and the Internet puts them all into a huge convenient circus tent, phishing, pharming, and other spoofing attacks have risen to the top as the most dangerous computer security risks. When your bank can no longer send you email and you stop believing that your friends are your friends, we have a serious problem. Markus and Steve go far beyond the basics of problem exposition, covering solutions, legal status, and advanced research. Buy this book today and gird yourself for battle against the identity thieves.

DR. GARY MCGRAW

www.cigital.com

podcast www.cigital.com/silverbullet

book www.swsec.com

Phishing and Countmeasures is one of those rare volumes that speaks to the maturity of the information security arts as a truly synthesizing discipline; one that can substantially engage the many human and technical aspects that attend the phishing threat, in all its manifestations. While the volume provides a sweeping and detailed investigation into the technologies that are exploited by phishers, this compendium distinguishes itself with chapters examining end users' behavioral vulnerabilities, factors that ably assist phishers and, in some cases, actually neutralize counter-phishing technologies. It's a keystone volume for the library of the software engineer, interface designer, or the policy investigator who seeks an authoritative overview of both the technical and human factors that help animate the phishers' enterprise.

PETER CASSIDY

Secretary General, Anti-Phishing Working Group

Director of Research,

TriArche Research Group

Over the last several years, the Internet has evolved and matured. More and more individuals and corporations depend on the Internet for everything from banking and personal finance to travel and weather information, and of course, shopping, news, and personal communication. Unfortunately, this revolutionary new technology has a dark side in the form of scammers and outright criminals who play on the innocence and gullibility of average computer users to steal their personal information and compromise their identities. In this landmark book, Jakobsson and Myers do an outstanding job identifying and demystifying the techniques of the bad guys. They also describe what you can do to protect yourself and counter these threats. This book is a must read for anyone who has any presence online.

PROFESSOR AVIEL D. RUBIN

Johns Hopkins University

Author of *Brave New Ballot* (Random House, 2006)

This book is the encyclopedia of phishing. It provides views from the payment, human, and technical perspectives. The material is remarkably readable—each chapter is contributed by an expert on that topic, but none require specialized background on the part of the reader. The text will be useful for any professional who seeks to understand phishing.

DIRECTORS of the International Financial
Cryptography Association (IFCA)

Phishing and Countermeasures



THE WILEY BICENTENNIAL—KNOWLEDGE FOR GENERATIONS

Each generation has its unique needs and aspirations. When Charles Wiley first opened his small printing shop in lower Manhattan in 1807, it was a generation of boundless potential searching for an identity. And we were there, helping to define a new American literary tradition. Over half a century later, in the midst of the Second Industrial Revolution, it was a generation focused on building the future. Once again, we were there, supplying the critical scientific, technical, and engineering knowledge that helped frame the world. Throughout the 20th Century, and into the new millennium, nations began to reach out beyond their own borders and a new international community was born. Wiley was there, expanding its operations around the world to enable a global exchange of ideas, opinions, and know-how.

For 200 years, Wiley has been an integral part of each generation's journey, enabling the flow of information and understanding necessary to meet their needs and fulfill their aspirations. Today, bold new technologies are changing the way we live and learn. Wiley will be there, providing you the must-have knowledge you need to imagine new worlds, new possibilities, and new opportunities.

Generations come and go, but you can always count on Wiley to provide you the knowledge you need, when and where you need it!

WILLIAM J. PESCE
PRESIDENT AND CHIEF EXECUTIVE OFFICER

PETER BOOTH WILEY
CHAIRMAN OF THE BOARD

Phishing and Countermeasures

Understanding the Increasing Problem
of Electronic Identity Theft

Edited by

Markus Jakobsson

Indiana University
Bloomington, Indiana

Steven Myers

Indiana University
Bloomington, Indiana



WILEY-INTERSCIENCE
A JOHN WILEY & SONS, INC., PUBLICATION

Cover design by Sukamol Srikwan

Copyright © 2007 by John Wiley & Sons, Inc. All rights reserved.

Published by John Wiley & Sons, Inc., Hoboken, New Jersey.

Published simultaneously in Canada.

No part of this publication may be reproduced, stored in a retrieval system, or transmitted in any form or by any means, electronic, mechanical, photocopying, recording, scanning, or otherwise, except as permitted under Section 107 or 108 of the 1976 United States Copyright Act, without either the prior written permission of the Publisher, or authorization through payment of the appropriate per-copy fee to the Copyright Clearance Center, Inc., 222 Rosewood Drive, Danvers, MA 01923, (978) 750-8400, fax (978) 750-4470, or on the web at www.copyright.com. Requests to the Publisher for permission should be addressed to the Permissions Department, John Wiley & Sons, Inc., 111 River Street, Hoboken, NJ 07030, (201) 748-6011, fax (201) 748-6008, or online at <http://www.wiley.com/go/permission>.

Limit of Liability/Disclaimer of Warranty: While the publisher and author have used their best efforts in preparing this book, they make no representations or warranties with respect to the accuracy or completeness of the contents of this book and specifically disclaim any implied warranties of merchantability or fitness for a particular purpose. No warranty may be created or extended by sales representatives or written sales materials. The advice and strategies contained herein may not be suitable for your situation. You should consult with a professional where appropriate. Neither the publisher nor author shall be liable for any loss of profit or any other commercial damages, including but not limited to special, incidental, consequential, or other damages.

For general information on our other products and services or for technical support, please contact our Customer Care Department within the United States at (800) 762-2974, outside the United States at (317) 572-3993 or fax (317) 572-4002.

Wiley also publishes its books in a variety of electronic formats. Some content that appears in print may not be available in electronic format. For information about Wiley products, visit our web site at www.wiley.com.

Library of Congress Cataloging-in-Publication Data:

Jakobsson, Markus.

Phishing and countermeasures: understanding the increasing problem of electronic identity theft / Markus Jakobsson, Steven Myers.

p. cm.

Includes Index.

ISBN-13 978-0-471-78245-2 (cloth)

ISBN-10 0-471-78245-9 (cloth)

1. Phishing. 2. Identity theft - Prevention. 3. Computer security.

I. Myers, Steven, 1975- , II. Title.

HV6773.J345 2006

364.16'3 --dc22

2006016019

Printed in the United States of America.

10 9 8 7 6 5 4 3 2 1

CONTENTS

Preface	xix
Acknowledgements	xxiv
1 Introduction to Phishing	1
1.1 What is Phishing?	1
1.2 A Brief History of Phishing	2
1.3 The Costs to Society of Phishing	4
1.4 A Typical Phishing Attack	5
1.4.1 Phishing Example: America's Credit Unions	6
1.4.2 Phishing Example: PayPal	10
1.4.3 Making the Lure Convincing	12
1.4.4 Setting The Hook	18
1.4.5 Making the Hook Convincing	20
1.4.6 The Catch	22
1.4.7 Take-Down and Related Technologies	23
1.5 Evolution of Phishing	23
1.6 Case Study: Phishing on Froogle	24
1.7 Protecting Users from Phishing	28
References	29
	vii

2	Phishing Attacks: Information Flow and Chokepoints	31
2.1	Types of Phishing Attacks	32
2.1.1	Deceptive Phishing	32
2.1.2	Malware-Based Phishing	34
2.1.3	DNS-Based Phishing (“Pharming”)	35
2.1.4	Content-Injection Phishing	36
2.1.5	Man-in-the-Middle Phishing	36
2.1.6	Search Engine Phishing	37
2.2	Technology, Chokepoints, and Countermeasures	37
2.2.1	Step 0: Preventing a Phishing Attack Before It Begins	38
2.2.2	Step 1: Preventing Delivery of Phishing Payload	40
2.2.3	Step 2: Preventing or Disrupting a User Action	43
2.2.4	Steps 2 and 4: Prevent Navigation and Data Compromise	49
2.2.5	Step 3: Preventing Transmission of the Prompt	50
2.2.6	Step 4: Preventing Transmission of Confidential Information	52
2.2.7	Steps 4 and 6: Preventing Data Entry and Rendering It Useless	55
2.2.8	Step 5: Tracing Transmission of Compromised Credentials	57
2.2.9	Step 6: Interfering with the Use of Compromised Information	58
2.2.10	Step 7: Interfering with the Financial Benefit	62
	References	62
3	Spoofing and Countermeasures	65
3.1	Email Spoofing	65
3.1.1	Filtering	68
3.1.2	Whitelisting and Greylisting	70
3.1.3	Anti-spam Proposals	71
3.1.4	User Education	73
3.2	IP Spoofing	74
3.2.1	IP Traceback	75
3.2.2	IP Spoofing Prevention	78
3.2.3	Intradomain Spoofing	80
3.3	Homograph Attacks Using Unicode	81
3.3.1	Homograph Attacks	81
3.3.2	Similar Unicode String Generation	82
3.3.3	Methodology of Homograph Attack Detection	83

3.4	Simulated Browser Attack	89
3.4.1	Using the Illusion	93
3.4.2	Web Spoofing	94
3.4.3	SSL and Web Spoofing	96
3.4.4	Ensnaring the User	98
3.4.5	SpoofGuard Versus the Simulated Browser Attack	99
3.5	Case Study: Warning the User About Active Web Spoofing	101
	References	102

4 Pharming and Client Side Attacks 105

4.1	Malware	105
4.1.1	Viruses and Worms	106
4.1.2	Spyware	115
4.1.3	Adware	115
4.1.4	Browser Hijackers	115
4.1.5	Keyloggers	116
4.1.6	Trojan Horses	116
4.1.7	Rootkits	116
4.1.8	Session Hijackers	118
4.2	Malware Defense Strategies	118
4.2.1	Defense Against Worms and Viruses	118
4.2.2	Defense Against Spyware and Keyloggers	121
4.2.3	Defense Against Rootkits	121
4.3	Pharming	122
4.3.1	Overview of DNS	123
4.3.2	Role of DNS in Pharming	124
4.3.3	Defense Against Pharming	125
4.4	Case Study: Pharming with Appliances	126
4.4.1	A Different Phishing Strategy	127
4.4.2	The Spoof: A Home Pharming Appliance	128
4.4.3	Sustainability of Distribution in the Online Marketplace	131
4.4.4	Countermeasures	132
4.5	Case Study: Race-Pharming	133
4.5.1	Technical Description	134
4.5.2	Detection and Countermeasures	135
4.5.3	Contrast with DNS Pharming	136
	References	137

5	Status Quo Security Tools	139
5.1	An Overview of Anti-Spam Techniques	139
5.2	Public Key Cryptography and its Infrastructure	144
5.2.1	Public Key Encryption	145
5.2.2	Digital Signatures	146
5.2.3	Certificates & Certificate Authorities	147
5.2.4	Certificates	149
5.3	SSL Without a PKI	151
5.3.1	Modes of Authentication	152
5.3.2	The Handshaking Protocol	152
5.3.3	SSL in the Browser	155
5.4	Honeypots	159
5.4.1	Advantages and Disadvantages	161
5.4.2	Technical Details	162
5.4.3	Honeypots and the Security Process	166
5.4.4	Email Honeypots	168
5.4.5	Phishing Tools and Tactics	170
	References	172
6	Adding Context to Phishing Attacks: Spear Phishing	175
6.1	Overview of Context Aware Phishing	175
6.2	Modeling Phishing Attacks	177
6.2.1	Stages of Context Aware Attacks	182
6.2.2	Identity Linking	185
6.2.3	Analyzing the General Case	187
6.2.4	Analysis of One Example Attack	190
6.2.5	Defenses Against Our Example Attacks	190
6.3	Case Study: Automated Trawling for Public Private Data	191
6.3.1	Mother's Maiden Name: Plan of Attack	193
6.3.2	Availability of Vital Information	193
6.3.3	Heuristics for MMN Discovery	194
6.3.4	Experimental Design	196
6.3.5	Assessing the Damage	196
6.3.6	Time and Space Heuristics	198
6.3.7	MMN Compromise in Suffixed Children	199
6.3.8	Other Ways to Derive Mother's Maiden Names	199

6.4	Case Study: Using Your Social Network Against You	202
6.4.1	Motivations of a Social Phishing Attack Experiment	203
6.4.2	Design Considerations	203
6.4.3	Data Mining	204
6.4.4	Performing the Attack	206
6.4.5	Results	207
6.4.6	Reactions Expressed in Experiment Blog	208
6.5	Case Study: Browser Recon Attacks	210
6.5.1	Who Cares Where I've Been?	210
6.5.2	Mining Your History	211
6.5.3	CSS to Mine History	216
6.5.4	Bookmarks	218
6.5.5	Various Uses for Browser-Recon	218
6.5.6	Protecting Against Browser Recon Attacks	218
6.6	Case Study: Using the Autofill Feature in Phishing	219
6.7	Case Study: Acoustic Keyboard Emanations	221
6.7.1	Previous Attacks of Acoustic Emanations	223
6.7.2	Description of Attack	223
6.7.3	Technical Details	226
6.7.4	Experiments	231
	References	237
7	Human-Centered Design Considerations	241
7.1	Introduction: The Human Context of Phishing and Online Security	241
7.1.1	Human Behavior	241
7.1.2	Browser and Security Protocol Issues in the Human Context	243
7.1.3	Overview of the HCI and Security Literature	246
7.2	Understanding and Designing for Users	247
7.2.1	Understanding Users and Security	248
7.2.2	Designing Usable Secure Systems	255
7.3	Mis-Education	260
7.3.1	How Does Learning Occur?	260
7.3.2	The Lessons	261
7.3.3	Learning to Be Phished	269
7.3.4	Solution Framework	271
	References	273

8	Passwords	277
8.1	Traditional Passwords	277
8.1.1	Cleartext Passwords	277
8.1.2	Password Recycling	278
8.1.3	Hashed Passwords	278
8.1.4	Brute Force Attacks	280
8.1.5	Dictionary Attacks	281
8.1.6	Time-Memory Tradeoffs	281
8.1.7	Salted Passwords	283
8.1.8	Eavesdropping	284
8.1.9	One-Time Passwords	285
8.1.10	Alternatives to Passwords	285
8.2	Case Study: Phishing in Germany	286
8.2.1	Comparison of Procedures	286
8.2.2	Recent Changes and New Challenges	286
8.3	Security Questions as Password Reset Mechanisms	290
8.3.1	Knowledge-Based Authentication	291
8.3.2	Security Properties of Life Questions	292
8.3.3	Protocols Using Life Questions	296
8.3.4	Example Systems	298
8.4	One-Time Password Tokens	301
8.4.1	OTPs as a Phishing Countermeasure	306
8.4.2	Advanced Concepts	306
	References	308
9	Mutual Authentication and Trusted Pathways	309
9.1	The Need for Reliable Mutual Authentication	309
9.1.1	Distinctions Between the Physical and Virtual World	310
9.1.2	The State of Current Mutual Authentication	311
9.2	Password Authenticated Key Exchange	312
9.2.1	A Comparison Between PAKE and SSL	312
9.2.2	An Example PAKE Protocol: SPEKE	313
9.2.3	Other PAKE Protocols and Some Augmented Variations	316
9.2.4	Doppelganger Attacks on PAKE	317
9.3	Delayed Password Disclosure	318
9.3.1	DPD Security Guarantees	320
9.3.2	A DPD Protocol	323

9.4	Trusted Path: How To Find Trust in an Unscrupulous World	327
9.4.1	Trust on the World Wide Web	328
9.4.2	Trust Model: Extended Conventional Model	329
9.4.3	Trust Model: Xenophobia	333
9.4.4	Trust Model: Untrusted Local Computer	333
9.4.5	Trust Model: Untrusted Recipient	335
9.4.6	Usability Considerations	338
9.5	Dynamic Security Skins	339
9.5.1	Security Properties	340
9.5.2	Why Phishing Works	340
9.5.3	Dynamic Security Skins	341
9.5.4	User Interaction	349
9.5.5	Security Analysis	350
9.6	Browser Enhancements for Preventing Phishing	351
9.6.1	Goals for Anti-Phishing Techniques	353
9.6.2	Google Safe Browsing	354
9.6.3	Phoolproof Phishing Prevention	358
9.6.4	Final Design of the Two-Factor Authentication System	360
	References	364
10	Biometrics and Authentication	369
10.1	Biometrics	369
10.1.1	Fundamentals of Biometric Authentication	371
10.1.2	Biometrics and Cryptography	377
10.1.3	Biometrics and Phishing	382
10.1.4	Phishing Biometric Characteristics	384
10.2	Hardware Tokens for Authentication and Authorization	385
10.3	Trusted Computing Platforms and Secure Operating Systems	387
10.3.1	Protecting Against Information Harvesting	392
10.3.2	Protecting Against Information Snooping	398
10.3.3	Protecting Against Redirection	405
10.4	Secure Dongles and PDAs	407
10.4.1	The Promise and Problems of PKI	408
10.4.2	Smart Cards and USB Dongles to Mitigate Risk	409
10.4.3	PorKI Design and Use	413
10.4.4	PorKI Evaluation	416
10.4.5	New Applications and Directions	419

10.5	Cookies for Authentication	420
10.5.1	Cache-Cookie Memory Management	423
10.5.2	Cache-Cookie Memory	423
10.5.3	C-Memory	424
10.5.4	TIF-Based Cache Cookies	425
10.5.5	Schemes for User Identification and Authentication	425
10.5.6	Identifier Trees	427
10.5.7	Rolling-Pseudonym Scheme	429
10.5.8	Denial-of-Service Attacks	430
10.5.9	Secret Cache Cookies	431
10.5.10	Audit Mechanisms	432
10.5.11	Proprietary Identifier-Trees	433
10.5.12	Implementation	434
10.6	Lightweight Email Signatures	435
10.6.1	Cryptographic and System Preliminaries	438
10.6.2	Lightweight Email Signatures	439
10.6.3	Technology Adoption	444
10.6.4	Vulnerabilities	447
10.6.5	Experimental Results	449
	References	453
11	Making Takedown Difficult	461
11.1	Detection and Takedown	461
11.1.1	Avoiding Distributed Phishing Attacks—Overview	464
11.1.2	Collection of Candidate Phishing Emails	465
11.1.3	Classification of Phishing Emails	465
	References	467
12	Protecting Browser State	469
12.1	Client-Side Protection of Browser State	469
12.1.1	Same-Origin Principle	470
12.1.2	Protecting Cache	473
12.1.3	Protecting Visited Links	474

12.2	Server-Side Protection of Browser State	476
12.2.1	Goals	478
12.2.2	A Server-Side Solution	480
12.2.3	Pseudonyms	481
12.2.4	Translation Policies	485
12.2.5	Special Cases	486
12.2.6	Security Argument	486
12.2.7	Implementation Details	487
12.2.8	Pseudonyms and Translation	487
12.2.9	General Considerations	490
	References	491
13	Browser Toolbars	493
13.1	Browser-Based Anti-Phishing Tools	493
13.1.1	Information-Oriented Tools	494
13.1.2	Database-Oriented Tools	501
13.1.3	Domain-Oriented Tools	507
13.2	Do Browser Toolbars Actually Prevent Phishing?	514
13.2.1	Study Design	514
13.2.2	Results and Discussion	517
	References	521
14	Social Networks	523
14.1	The Role of Trust Online	524
14.2	Existing Solutions for Securing Trust Online	527
14.2.1	Reputation Systems and Social Networks	527
14.2.2	Third-Party Certifications	532
14.2.3	First-Party Assertions	534
14.2.4	Existing Solutions for Securing Trust Online	535
14.3	Case Study: “Net Trust”	535
14.3.1	Identity	538
14.3.2	The Buddy List	539
14.3.3	The Security Policy	542
14.3.4	The Rating System	542
14.3.5	The Reputation System	543
14.3.6	Privacy Considerations and Anonymity Models	546
14.3.7	Usability Study Results	546
14.4	The Risk of Social Networks	548
	References	549

15 Microsoft's Anti-Phishing Technologies and Tactics	551
15.1 Cutting the Bait: SmartScreen Detection of Email Spam and Scams	552
15.2 Cutting the Hook: Dynamic Protection Within the Web Browser	556
15.3 Prescriptive Guidance and Education for Users	560
15.4 Ongoing Collaboration, Education, and Innovation	561
References	562
 16 Using S/MIME	 563
16.1 Secure Electronic Mail: A Brief History	564
16.1.1 The Key Certification Problem	565
16.1.2 Sending Secure Email: Usability Concerns	567
16.1.3 The Need to Redirect Focus	568
16.2 Amazon.com's Experience with S/MIME	569
16.2.1 Survey Methodology	569
16.2.2 Awareness of Cryptographic Capabilities	570
16.2.3 Segmenting the Respondents	573
16.2.4 Appropriate Uses of Signing and Sealing	574
16.3 Signatures Without Sealing	574
16.3.1 Evaluating the Usability Impact of S/MIME-Signed Messages	576
16.3.2 Problems from the Field	582
16.4 Conclusions and Recommendations	586
16.4.1 Promote Incremental Deployment	587
16.4.2 Extending Security from the Walled Garden	588
16.4.3 S/MIME for Webmail	589
16.4.4 Improving the S/MIME Client	590
References	590
 17 Experimental evaluation of attacks and countermeasures	 595
17.1 Behavioral Studies	595
17.1.1 Targets of Behavioral Studies	596
17.1.2 Techniques of Behavioral Studies for Security	597
17.1.3 Strategic and Tactical Studies	599
17.2 Case Study: Attacking eBay Users with Queries	600
17.2.1 User-to-User Phishing on eBay	602
17.2.2 eBay Phishing Scenarios	608
17.2.3 Experiment Design	609
17.2.4 Methodology	615
17.3 Case Study: Signed Applets	618
17.3.1 Trusting Applets	618
17.3.2 Exploiting Applets' Abilities	619
17.3.3 Understanding the Potential Impact	621

17.4	Case Study: Ethically Studying Man in the Middle	622
17.4.1	Man-in-the-Middle and Phishing	623
17.4.2	Experiment: Design Goals and Theme	628
17.4.3	Experiment: Man-in-the-Middle Technique Implementation	629
17.4.4	Experiment: Participant Preparation	632
17.4.5	Experiment: Phishing Delivery Method	634
17.4.6	Experiment: Debriefing	635
17.4.7	Preliminary Findings	635
17.5	Legal Considerations in Phishing Research	640
17.5.1	Specific Federal and State Laws	641
17.5.2	Contract Law: Business Terms of Use	651
17.5.3	Potential Tort Liability	652
17.5.4	The Scope of Risk	654
17.6	Case Study: Designing and Conducting Phishing Experiments	655
17.6.1	Ethics and Regulation	657
17.6.2	Phishing Experiments - Three Case Studies	661
17.6.3	Making It Look Like Phishing	665
17.6.4	Subject Reactions	666
17.6.5	The Issue of Timeliness	667
	References	668
18	Liability for Phishing	671
18.1	Impersonation	671
18.1.1	Anti-SPAM	671
18.1.2	Trademark	674
18.1.3	Copyright	674
18.2	Obtaining Personal Information	675
18.2.1	Fraudulent Access	675
18.2.2	Identity Theft	676
18.2.3	Wire Fraud	677
18.2.4	Pretexting	677
18.2.5	Unfair Trade Practice	678
18.2.6	Phishing-Specific Legislation	678
18.2.7	Theft	680
18.3	Exploiting Personal Information	680
18.3.1	Fraud	680
18.3.2	Identity Theft	681
18.3.3	Illegal Computer Access	682
18.3.4	Trespass to Chattels	682
	References	685

19 The Future	687
References	694
Index	695
About the Editors	700

PREFACE

What Is Phishing?

Imagine that phishing were legal. Wall street would have hailed it and its dominant players as the new market wonders, challenging today's stock market stars. Some newspapers would have praised it for its telecommuting opportunities, others would have fretted about the outsourcing. Universities would have offered courses on how to do the data collection to set up attacks, how to determine the best timing, and on how, in general, to improve the yield. Bumper stickers would have proclaimed "I would rather be phishing."

But if phishing were to become legalized right now, as you read this line, would the number of attacks have mushroomed beyond the current trend by next week, or even next month? We argue they may not, at least not that quickly. The reason we believe this to be the case is simply that it is not the law that holds criminals back, it only geographically restricts where the phishing attacks will originate from — typically, from countries where the police corps has more immediate concerns than abstract crimes against people in other jurisdictions. Given the excellent economy of scale of phishing and the transportability of the threat, this geographic restriction may not translate into any notable limitation of the problem.

To the extent that phishing is held back at all today, we believe this to be caused to a large extent simply by the lack of sophistication among phishers. It is still today very common to see poorly spelt phishing lures with content that the recipients cannot relate to. The costs of mounting attacks are so low that there is not enough motivation for what would have been called professionalism, had phishing been legal. In other words, the yield is "good enough" to allow phishers to be sloppy. Then what will happen when some group of more competent phishers decide that they are not satisfied with what they currently get?

Unfortunately, there is plenty of room for refinement. As argued in many places in this book, attacks can — and will — get much worse. The yield of attacks may increase from a percent or less to well above fifty percent, simply by taking advantage of all available information and crafting attacks more carefully.

While educational campaigns may temporarily help in the effort against phishing, we do not believe they will have any noticeable long-term benefit. The reason for this is that *phishers* will also be educated by these campaigns and will quickly learn how to use special cases that will not fall under the general descriptions of what users are told to be wary of. At the same time, users will be constantly worried (having learned about so many ways in which they can be deceived) that they may actually shun many legitimate offers.

In spite of the fact that phishing is equal parts technology and psychology, we believe that our remaining hope in the war against phishing is technology. Such technology must be based on a solid understanding of how things may go wrong — whether the problem resides on the network, on individual computers, or in the design of user interfaces. As often seen in computer security, the defenders have to wear the hat of the attackers to be able to understand how to best do their job. While the defenders certainly won't have to victimize people for real, they must be able to develop attacks and discuss these with their peers. Information about such new attacks will invariably leak to the dark side, but by then — hopefully — the deployment of appropriate countermeasures is on its way.

This book aims to lay the foundation for the effort of understanding phishing and devising anti-phishing techniques. It is intended for readers with some exposure to computer science, but in general does not demand any expert knowledge. We hope that it will be useful as an undergraduate- and graduate-level textbook and as a reference book for system administrators and web developers. It may also be highly relevant to engineers in the areas of wireless communication, as well as to specialists in banking. We further hope that the book will guide the efforts of law- and policy-makers, because an accurate understanding of both threats and countermeasures is vital in the design of meaningful laws and policies. While we do not think that laws and policies are the primary vehicles in the fight against phishing, we hope that they can aid in this effort — at the very least in establishing what exactly constitutes due diligence. Finally, parts of the book will be highly relevant to institutional review boards. If the criminal trend of phishing attacks is any predictor of the likely future efforts in performing experiments to judge the severity of attacks and the success rates of countermeasures, then a large number of phishing experiments will be designed and be submitted for human subjects approval. We provide some guidance to how to assess such applications, which may be helpful both to members of institutional review boards and researchers.

While most of the book is fairly easily accessible to the above-mentioned groups of potential readers, there are some highly technical parts that may be appreciated mostly by researchers in the emerging field of anti-phishing and by system designers with particular interests in a given area. Others may skip over these segments without any great loss of context.

How to Read This Book

Depending on who you are, you will want to read this book in different ways. The book, after all, is not written with one single group of readers in mind, but is intended for a wide audience. This is reflected both by the spread of topics and the fact that each chapter has a little bit for the interested newcomer and a little bit for the knowledgeable specialist.

For simplicity, we can break up the readership in the following general groups: *computer scientists, students of interface design and human behavior, specialists of law and policy, members of institutional review boards, software developers, system administrators, and readers who will use the book primarily as a reference.* Depending on which ones of these roles fits you the best, here is how we would suggest that you start reading the book:

How to Read This Book — for Computer Scientists Computer scientists are likely to enjoy almost any part of the book. In the four first chapters, you will get a good overview of the problem, and in the fifth chapter some common countermeasures are described. You may already know much of this material, but the overview may still be beneficial to you.

Chapter 6 introduces a new type of threat, namely spear phishing. This is a type of phishing attack that infers (or manipulates) the context of a given victim before mounting a personalized attack. Given the many ways to collect and manipulate data, this is likely to become a serious threat.

Chapter 7 describes another set of vulnerabilities that are associated with both machines and humans. In computer science, it is an all too common mistake to underestimate the impact of normal human behavior. While it makes perfect sense to design a system so that it is secure when used as it should, it makes even more sense to design it so that it is secure even when it is *not* used properly. Humans make mistakes, and technology must respect that. Read the seventh chapter, thinking not of *you* as the intended user, but rather a friend or family member without any substantial technology background — and with nobody to ask for help. That is the average computer user.

Chapters 8 and 9 describe how machines can verify the authenticity of humans. Chapter 10 describes how machines can verify the authenticity of humans or machines based on physical conditions, such as biometrics or special-purpose hardware. While you may have heard about some of these techniques, chances are that others will be new to you.

Chapter 11 introduces a new type of phishing attack that threatens to complicate centralized defense measures — unfortunately, without any clear countermeasures being spelled out. We hope this threat can be addressed by people like you.

Chapters 12 to 15 describe different security measures associated with browsers, where the latter of these chapters describes Microsoft's current anti-phishing approach.

Chapter 16 highlights some problems associated with the use of certificates due to how users react to these. Like Chapter 7, this is a chapter we hope you will take seriously when you think about designing a new security tool. It does not matter how much security a given tool provides when used correctly if it is typically not used in this way.

Chapter 17 will be of particular interest to those of you who are interested in understanding the exact danger of given threats, or the exact security benefits achieved by given security tools. This chapter will describe some methods to assess and quantify the exact risks that users face in given situations, along with the ethical, technical and legal considerations associated with this type of approach.

Chapter 18 describes why phishing is not legal in the United States, and what is done to limit its spread using the law. We end the book in Chapter 19 with our view of the future.

While some parts of the book are exclusively intended for researchers and practitioners with detailed knowledge of the problem, at least half of the material is easily accessible to a general audience of computer scientists. If you belong to this group, you will be able to study the details of areas of particular interest to you after having looked up some basic material on the topic, in cases where this is not possible to cover in the book.

How to Read This Book — for HCI/D Students and Researchers The two first chapters provides a good overview of the problem of phishing, without delving into technical detail. These chapters are important for you to read to understand the complexity of the problem. Chapters 3 to 5 describe issues in more detail and Chapter 6 describes the concept of *spear phishing*. Chapter 7 describes the problem of phishing from the perspective of HCI researchers.

Chapters 8 and 9 describe password related issues; these are chapters of likely importance to you. While some portions may be on the technical side, you can skip to the next component if you find one component hard to follow, coming back to difficult components later on. These chapters raises important questions: How can alerts be communicated when a user is under attack? and How are reinforcing messages best communicated?

Chapter 10 describes how machines can verify the authenticity of humans or machines based on physical conditions, such as biometrics or special-purpose hardware. This chapter may be beneficial for you to at least browse through.

Chapters 12 to 15 describe different security measures associated with browsers, often touching on issues relating to how communicate alerts and go-aheads to users. Chapter 16 highlights some problems associated with the use of certificates due to how users react to these. You will recognize the issues described in there as problems arising from technical development that fails to consider usability.

Chapter 17 poses the question of how to best assess risks arising from phishing, and describes an alternative approach to closed-lab tests and surveys.

The book ends with a description of legal issues of phishing (Chapter 18) and our vision of the future (Chapter 19.)

How to Read This Book — for Specialists of Law and Policy We argue that it is critical for specialists of law and policy to understand the technical issues associated with the problem of phishing, as well as the achievements and limitations of defensive technologies. It will only be possible to develop meaningful reactions to abuses if you know what these are. In particular, the first two chapters give an overview of the problem of phishing; Chapter 5 describes common countermeasures; and Chapter 6 speaks of how knowledge about potential victims can be used to increase the yield of phishing attacks. While deep technical knowledge may not be essential to you, we believe that a clear sight of the big picture is critical. We argue that it is also important for specialists of law and policy to understand what possible limitations there are in terms of user education and user interaction; this makes Chapters 7 and 16 important. Legal issues of *phishing research* is described in Chapter 17; legal issues associated with *phishing* in Chapter 18. Chapter 19 ends the book with a description of the authors' view of future threats.

How to Read This Book — for Members of Institutional Review Boards The portions that will be the most helpful to you may be those that deal with phishing experiments, namely Chapters 16 and 17. These chapters describe some example experiments, along with the IRB process associated with these. You will also find a detailed description of the legal aspects associated with performing experiments in this chapter.

However, reading about experiments and how they were set up is not the only aspect of relevance to IRB members. We argue that it is important for you also to understand what the threats in general are (surveyed in the three first chapters) in order to understand the current threats: A study that does not increase the threat posed to a user in comparison to what he or she is already exposed to in everyday life is clearly easier to support than one that substantially increases the perception of threat. Another aspect of importance is to consider the impact of a potential attack in the future, if not understood and countered before it is too

late. Therefore, reading of chapters describing potential new types of threats (e.g., Chapters 6 and 11) is of importance to gain an understanding of the likely threat picture. It is also of importance, we believe, for members of IRBs to understand the potential relationship between technical, educational and legal approaches, because they may all come into play when designing experiments. Educational issues are covered in Chapter 5, legal issues are covered in Chapters 17 and 18, and technical aspects are found in most parts of the book.

When reading the book, it is important to realize that the different chapters and components are not ordered in terms of their accessibility, but rather with respect to the associated topics. This means that there may be very technically intricate portions interspersed in otherwise rather easily accessible material. Keep this in mind when you read the book: If the material appears hard to understand, skip ahead to the next section or chapter, and it may again become easier to understand. You can always go back to technically difficult components after first having built a good basic understanding of the issues, whether attacks or countermeasures.

How to read this book – for software developers and system administrators

For software developers, our advice is to start by gaining a good overview of the problem of phishing (first four chapters), and then browse the available tools and their shortcomings (chapter five, eight to ten, and twelve to fifteen). What we urge you to consider very, very carefully is the aspects surrounding user interfaces, and how the average user is likely to react to a given situation. This is described in chapters seven to nine and thirteen to sixteen). It is far too easy to assume that others will have the same skills and understanding as you do – and it is often not the case. Remember that you are designing or configuring a system not to protect *you*, but to protect people without any notable technical background. If they can use the system and relate to it, so can you. But the other way around is not necessarily the case.

How to Read This Book as a Reference At the end of each chapter, we list the articles, books, and other related sources used in the same chapter. These references will provide you with more in-depth information in cases where the book only covers part of the aspect, or leaves out technical proofs, definitions, or other material. In some places in the book, you will also see references to already published books that allow readers unfamiliar with given topics to read up on these. Such topics may not be of direct relevance to phishing, or may be known by many readers, or may simply be out of the scope of the book. In these cases, there will be reading suggestions in the sections of the book where this topic is covered, with references listed in detail at the end of the associated chapter.

Looking Ahead

While both threats and countermeasures will no doubt evolve, we believe that the basic principles behind these will not change as quickly as the individual techniques. Thus, we are certain that the book remain relevant even as new threats and countermeasures are developed, and hope that you will benefit from it for years to come.

Markus Jakobsson

Steve Myers

Bloomington, Indiana
September, 2006

ACKNOWLEDGMENTS

This book would not have been possible without the hard work of the researchers contributing chapters, sections and case studies to this book, and without the support they received from their employers. The following is list of all the researchers who contributed material to the book, where the order is alphabetical.

Ben Adida, Massachusetts Institute of Technology
Ruj Akavipat, Indiana University at Bloomington
Maxime Augier, École Polytechnique Fédérale De Lausanne
Jeffrey Bardzell, Indiana University at Bloomington
Eli Blevis, Indiana University at Bloomington
Dan Boneh, Stanford University
Andrew Bortz, Stanford University
Manfred Bromba, GmbH Biometrics, Germany
Jean Camp, Indiana University at Bloomington
Beth Cate, Indiana University at Bloomington
Fred Cate, Indiana University at Bloomington
David Chau, Massachusetts Institute of Technology
Christian Collberg, University of Arizona
Xiaotie Deng, City University of Hong Kong
Rachna Dhamija, Harvard University
Aaron Emigh, Radix Labs
Peter Finn, Indiana University at Bloomington
Anthony Fu, City University of Hong Kong
Simson Garfinkel, Harvard University
Alla Genkina, University of California at Los Angeles

Virgil Griffith, Indiana University at Bloomington
 Minaxi Gupta, Indiana University at Bloomington
 Susan Hohenberger, Massachusetts Institute of Technology
 Collin Jackson, Stanford University
 Tom N. Jagatic, Indiana University at Bloomington
 Markus Jakobsson, Indiana University at Bloomington
 Nathaniel A. Johnson, Indiana University at Bloomington
 Ari Juels, RSA Laboratories
 Angelos Keromytis, Columbia University
 Cynthia Kuo, Carnegie Mellon University
 Youn-Kyung Lim, Indiana University at Bloomington
 Mark Meiss, Indiana University at Bloomington
 Filippo Menczer, Indiana University at Bloomington
 Robert Miller, Massachusetts Institute of Technology
 John Mitchell, Stanford University
 Steven Myers, Indiana University at Bloomington
 Magnus Nyström, RSA Laboratories
 Bryan Parno, Carnegie Mellon University
 Adrian Perrig, Carnegie Mellon University
 Aza Raskin, Humanized, Inc.
 Jacob Ratkiewicz, Indiana University at Bloomington
 Ronald L. Rivest, Massachusetts Institute of Technology
 John L. Scarrow, Microsoft
 Sara Sinclair, Dartmouth College
 Sean Smith, Dartmouth College
 Sid Stamm, Indiana University at Bloomington
 Michael Stepp, University of California at San Diego
 Michael Szydlo, RSA Laboratories
 Alex Tsow, Indiana University at Bloomington
 J. D. Tygar, University of California at Berkeley
 Camilo Viecco, Indiana University at Bloomington
 Liu Wenyin, City University of Hong Kong
 Susanne Wetzels, Stevens Institute of Technology
 Min Wu, Massachusetts Institute of Technology
 Feng Zhou, University of California at Berkeley
 Li Zhuang, University of California at Berkeley

The effort of putting together a comprehensive book on the topic of phishing is a tremendous task, both given the amount of relevant work and the multi-faceted aspects of the same. Working day and night, we still would not have been able to achieve this goal without the significant help we were given from colleagues and friends, researchers, students and staff, all helping us towards the goal of making this book comprehensive, accessible, and timely.

Many of the components of this book were contributed by students and fellow researchers, who took time out of their hectic schedules to contribute chapters, sections and examples, drawing on their individual skills and knowledge, helping the book become the multi-faceted contribution to the field that it is. While the names of these specialists are listed at the beginning of their associated book components, there are many more who contributed. In particular, we were tremendously helped by Chris Murphy and Terri Taylor, who facilitated the communication between the editors and the contributors; and Liu Yang, who at times

was solely in charge of making the growing document adhere to the standards of LaTeX. We want to thank Farzaneh Asgharpour and Changwei Liu for their last-minute efforts to help us get things ready for publication. We owe the cover art to Sukamol Srikwan.

We have also benefitted from the advice and feedback of numerous colleagues and contributors. These, in turn have benefitted from support within their organizations. We therefore want to thank Gina Binole, Kris Iverson, Samantha McManus, Alyson Dawson and Jacqueline Beaucher. Furthermore, we wish to acknowledge the support received by our contributors. Portions of the chapter two were sponsored by the U.S. Department of Homeland Security, Science and Technology Directorate. Any opinions are those of the author and do not necessarily represent the official position of the U.S. Department of Homeland Security or the Science and Technology Directorate. Thanks are also due to the MailFrontier and Secure Science Corporation for some of the examples of customer communications of chapter 7.3.

Finally, we want to thank understanding family members who have witnessed the burdens associated with quickly producing a comprehensive scientific view – to the extent that this is possible – of a complex societal and technical problem. Phishing.

Markus Jakobsson

Steve Myers

Bloomington, Indiana

September, 2006

Phishing and Countermeasures

This Page Intentionally Left Blank